



DESTINATION

CERTIFICATION

CISSP

MindMaps



Domain 1

Security and Risk Management

Alignment of Security Function to Business Strategy

Corporate Governance

Security Governance

Focus of Security	Clearly Defined Roles & Responsibilities							Import/export controls	Transborder data flow	Privacy	Ethics	Corporate Laws		Risk Management	Procurement	Awareness, Training & Education			
												Overarching Security Policy							
												Functional Security Policies							
	Enable Business	Increase Value	Accountability	Responsibility	Due Care	Due Diligence	ITAR & EAR	Wassenaar Arrangement	(ISC) ² Code of Professional Ethics	Standards	Procedures	Baselines	Guidelines	Contracts & SLAs					

Privacy

State or condition of being free from being observed or disturbed by other people

Privacy policy

Personal Data

Data Lifecycle

OECD Guidelines

GDPR

Cannot Achieve Privacy
without Security

Standards
Procedures
Baselines
Guidelines

PII
SPI
PHI
PI

Direct Identifiers

Indirect Identifiers

Online Identifiers

Creation / Update

Store

Use

Share

Archive

Destroy

Collection Limitation

Data Quality

Purpose
Specification

Use Limitation

Security Safeguards

Openness

Individual
Participation

Accountability

Supervisory
Authority (SA)

Breaches reported within
72 hours

Intellectual Property

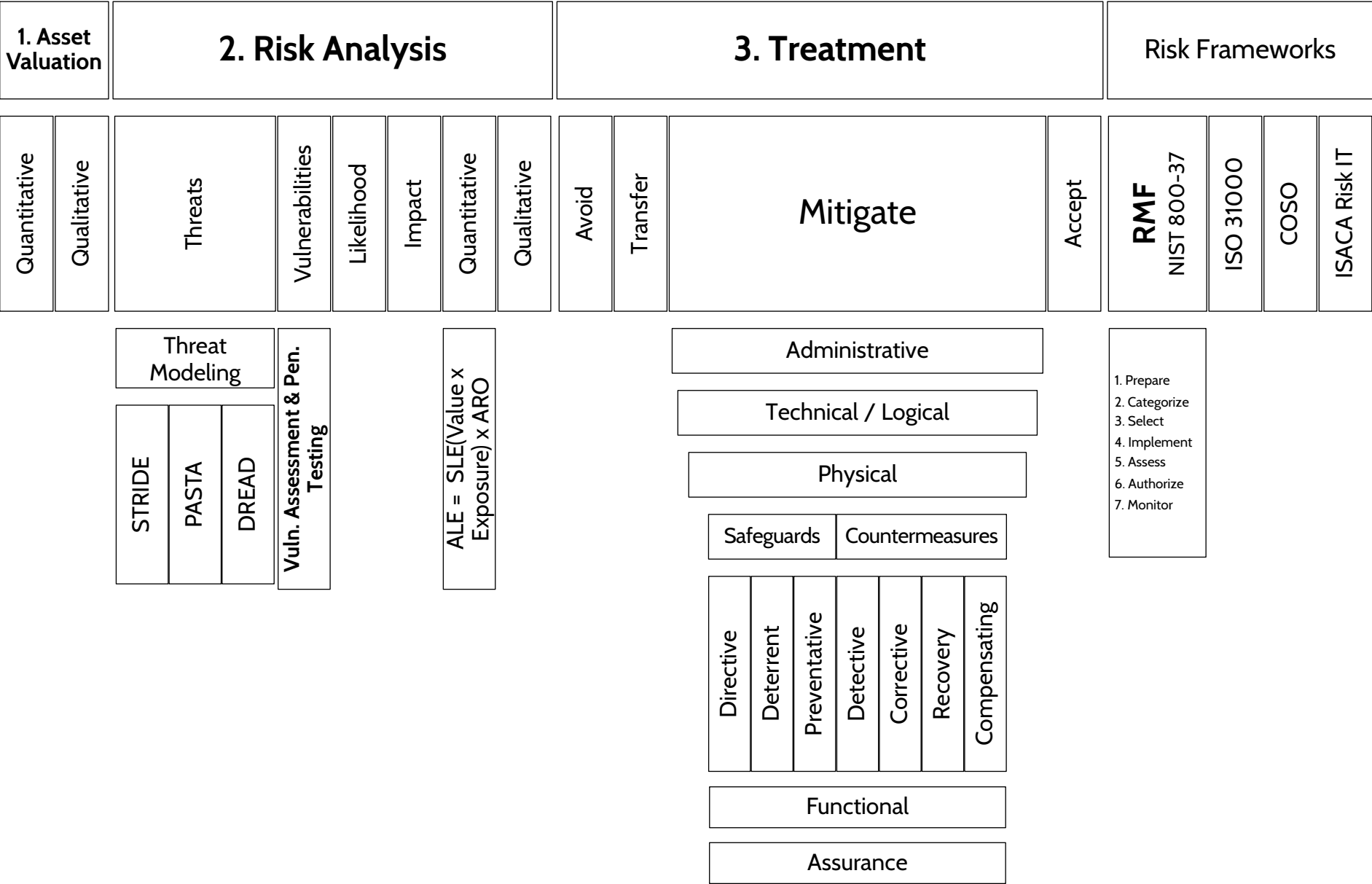
Trade Secret

Patent

Copyright

Trademark

Risk Management





Domain 2

Asset Security

Asset Classification

Asset Inventory

Assign Ownership

Classify

based on **Value**

Protect

based on **Classification**

Assess & Review

Data classification
policy

Classification

Categorization

Roles

Rest

Motion

Use

Archive

Defensible Destruction

DRM

DLP

Standards
Procedures
Baselines
Guidelines

Security Label

Security Marking

System Readable

Human Readable

Data Owner / Controller

Data Processor

Data Custodian

Data Steward

Data Subject

Encryption

Access Control

Backups

End-to-End

Link

Onion

Retention Period

Destruction

Purging

Clearing

Media Destruction

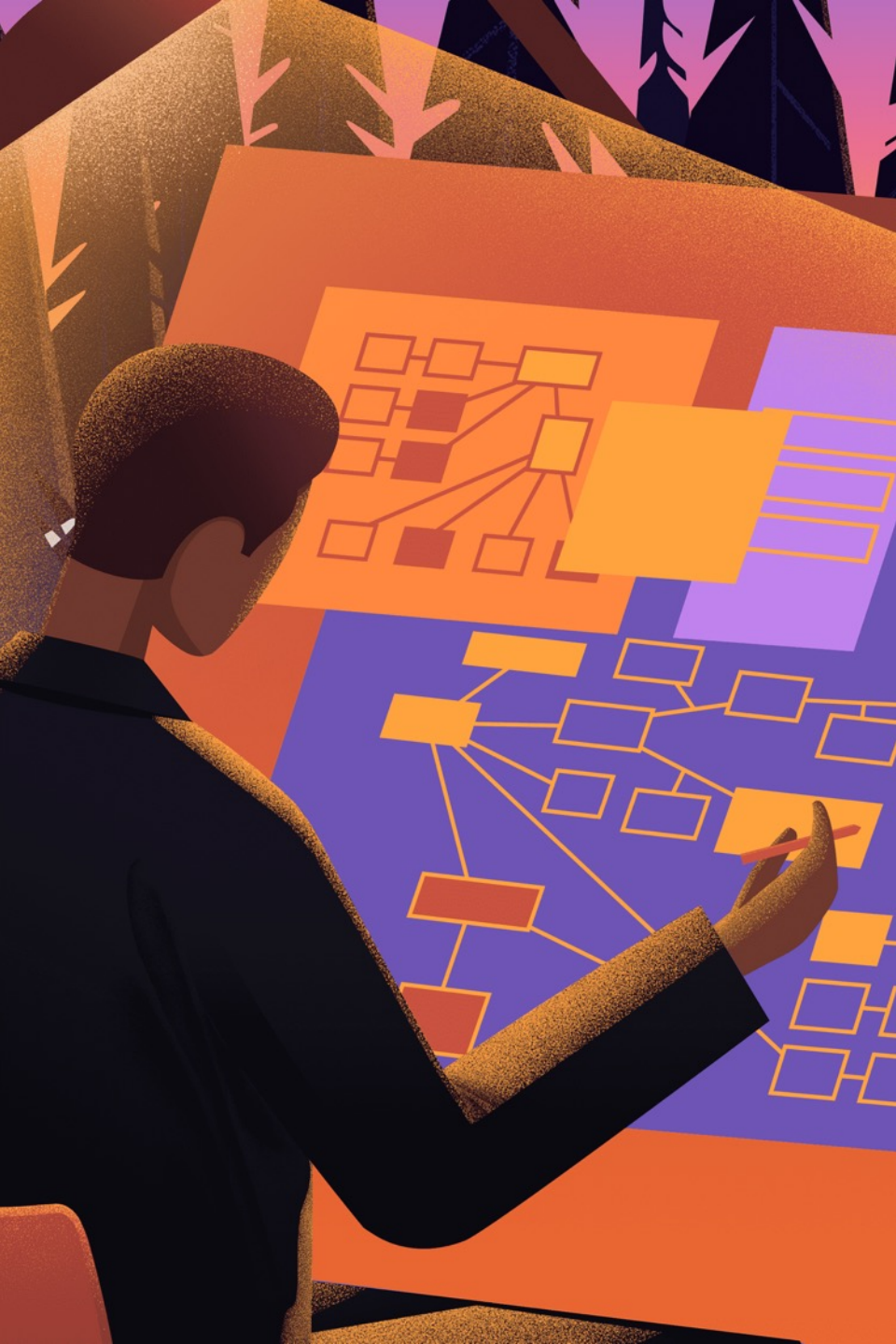
Shred / Disintegrate
/ Incinerate / Drill

Degauss

Crypto shredding

Overwrite / Wipe /
Erasure

Format



Domain 3

Security Architecture and Engineering

Models

Enterprise Security Architecture

Security Models

Zachman	Sabsa	TOGAF	Lattice Based					Rule Based			
			Bell- LaPadula		Biba		Lipner Implementation	Clark-Wilson	Brewer -Nash	Graham - Denning	Harrison -Ruzzo- Ullman
			Confidentiality	Simple Security Property	Star Property	Strong Star Property	Integrity	Simple Integrity Property	Star Integrity Property		
							3 goals of integrity		3 Clark-Wilson rules	Prevent conflicts of interest	

Secure Design Principles

Threat Modeling
Least Privilege
Defense in Depth
Secure Defaults
Fail Securely
Separation of Duties (SoD)
Keep it Simple
Zero Trust
Trust But Verify
Privacy by Design
Shared Responsibility

Security Frameworks

ISO 27001
ISO 27002
NIST 800-53
COBIT
ITIL
HIPAA
SOX
FedRAMP
FISMA
Cyber Kill Chain

Evaluation Criteria

Certification

Accreditation

TCSEC (Orange Book)

ITSEC

Common Criteria

Confidentiality only

Single Box only

Functional Levels

Confidentiality +
Integrity

Networked
devices

Same Functional
levels as TCSEC

Assurance Levels

ISO 15408

Protection
Profile

Target of
Evaluation

Security Targets

Functional &
Assurance
Requirements

Assign EAL

D1 – failed or not tested

C1 – Weak protection mechanisms

C2 – Strict login procedures

B1 – Security labels

B2 – Security labels and verification of no covert channels

B3 – Security labels, verification of no covert channels, and must stay secure during start-up

A1 – Verified design

E0

E1

E2

E3

E4

E5

E6

EAL1 – Functionally tested

EAL2 – Structurally tested

EAL3 – Methodically tested & checked

EAL4 – Methodically designed, tested & reviewed

EAL5 – Semi formally designed & tested

EAL6 – Semi formally verified designed & tested

EAL7 – Formally verified designed and tested

Trusted Computing Base (TCB)

Reference Monitor Concept			Hardware Components		Software Components		Protection Mechanisms													
Subject	Mediation	Object	Rules	Logging & Monitoring	Processor	Storage	System Kernel	Firmware	Middleware	Process Isolation	Processor States	Operating System Modes	Ring Protection Model	Secure Memory Management	Data Hiding	Defence in depth				
Security Kernel			Primary	Secondary	Virtual Memory	Memory Segmentation	Time Division Multiplexing	Problem	Supervisor	User Mode	Kernel Mode	Ring 3: User Programs	Ring 0: System Kernel							
Completeness			Isolation			Verifiability														

Vulnerabilities in Systems

Mobile Devices

OWASP Mobile Top 10

Single Point of Failure

Bypass Controls

TOCTOU
(Race Conditions)

Emanations

Covert Channels

Aggregation & Inference

Redundancy

Mitigating Controls

Increase frequency of Re-authentication

Shielding
(TEMPEST)

White Noise

Control Zones

Analysis & Design

Polyinstantiation

Policy, training & procedures

Remote access security

End-point security

M1: Improper Platform Usage

M2: Insecure Data Storage

M3: Insecure Communication

M4: Insecure Authentication

M5: Insufficient Cryptography

M6: Insecure Authorization

M7: Client Code Quality

M8: Code Tampering

M9: Reverse Engineering

M10: Extraneous Functionality

Web-based Vulnerabilities

Cross Site Scripting (XSS)

Cross Site Request Forgery (CSRF)

SQL Injection

Input Validation

Stored
(Persistent)

Reflected
(Most common)

DOM

Target of Attack: **Client**

Target of Attack: **Server**

Client Side vs. Server Side

Allow Lists vs. Deny Lists

Cloud Computing

	On-Demand Self Service	
	Broad Network Access	
	Resource Pooling	
	Rapid Elasticity	
	Measured Service	
	IaaS	
	PaaS	
	SaaS	
	Public	
	Private	
	Community	
	Hybrid	
	Virtual Machine	
	Containers	
	Serverless	
	Local	
	Cloud	
	Cloud	
	Linked	
	Synced	
	Federated	
	Accountable	
	Responsible	
	SPML	
	SAML	
	OpenID	
	OAuth	
	Data Centric	
	SLA	
	Snapshot, Virtual Disk, Image	
	Crypto Shredding / Crypto Erase	
	Cloud Consumer	
	Owner / Controller	
	Cloud Provider / Processor	
	Cloud Broker	
	Cloud Auditor	
	Hypervisor	
	Container Engine	
	Virtualized Compute	
	Identity Provider	
	Cloud identity	
	Roles	
	Protocols	
	Migration	
	Forensics	
	Data Destruction	
	Characteristics	
	Service Models	
	Deployment Models	
	Identity Provider	

Cryptographic Services

Confidentiality	Integrity	Authenticity	Non-Repudiation	Access Control
	= Hashing		Origin	Delivery

Cryptographic terminology

Plaintext	Encrypt	Key / Crypto variable	Decrypt	Key clustering	Work factor	Initialization vector/Nonce	Confusion	Diffusion	Avalanche
-----------	---------	-----------------------	---------	----------------	-------------	-----------------------------	-----------	-----------	-----------

Secret Writing

Hidden		Scrambled (Cryptography)									
Steganography	Null Cipher	One-way	Two-way						Substitution	Transposition	
		Hashing	Symmetric			Asymmetric			Caesar Cypher Monoalphabetic Polyalphabetic Running One-time Pads	Spartan Scytale Rail Fence (zigzag)	
		MD5 SHA-1 SHA-2 SHA-3	Block		Stream	Factoring	Discrete Log	Digital Certificates			Digital Signatures
			DES 3DES AES (Rijndael) CAST-128 SAFER Blowfish Twofish RC5/RC6	Block Modes: ECB CBC CFB OFB CTR	RC4	RSA	Diffie-Hellmann (key exchange) Elliptic Curve (ECC) El Gamal DSA				

Digital Signatures

Integrity

Authenticity

Non-repudiation

Origin

Delivery

Digital Certificates

Verify the owner of a Public Key

X.509

Replacement

Revocation

Pinning

CRL

OCSP

PKI

Certificate Authority
(Root of Trust)

Registration Authority

Intermediate / Issuing
CA

Certificate DB
(Revocation List)

Certificate Store
(Local)

Key Management

Kerchhoff's
Principle

Generation

Distribution

Storage

Rotation

Disposition

Recovery

Diffie-Hellmann
Out-of-band
Hybrid

TPM
HSM

Crypto-
shredding
Key Destruction

Split Knowledge
Dual Control
Key Escrow

Cryptanalysis

Cryptanalytic Attacks

Brute Force

Ciphertext Only

Known Plaintext

Chosen Plaintext

Chosen Ciphertext

Linear &
Differential

Factoring

Cryptographic Attacks

Man-in-
the-
middle

Replay

Pass the
Hash

Temporary
Files

Impleme-
ntation

Side Channel

Dictionary
Attack

Rainbow
Tables

Birthday
Attack

Social Engineering

Power

Timing

Radiation
Emissions

Purchase
Key

Rubber
Hose

Physical Security

Safety of people

Categories of Controls	Layered Defense																																											
Deter Delay Detect Assess Respond	Perimeter		Cameras		Passive Infrared Devices		Lighting		Card Readers / Badges		Doors / Mantraps		Locks		Windows		Walls		Skimming		Infrastructure				Fire Detection				Fire Suppression															
	Landscape		Grading		Mechanical		Digital		Shock		Glass break		Network		Power		HVAC		Flame (Infrared)														Smoke		Heat (Thermal)		Water		Gas		Extinguisher		CO ₂	
UPS		Generator		Power Outages		Power Degradation		Temperature		Humidity		Air Quality		Ionization		Photo-electric		Dual		Wet		Dry		Pre-action		Deluge		INERGE N Argonite FM-200 Aero-K																



Domain 4

Communication and Network Security

Open Systems Interconnection (OSI) Model

1. Physical		2. Datalink		3. Network		4. Transport		5. Session		6. Presentation		7. Appl.			
Media		Topologies		Collisions		Devices		Protocols		MAC Address		Devices		Protocols	
Wired: Twisted Pair, Coaxial, Fiber Optic		Wireless: Radio Frequency, Infrared, Microwave		Bus		Tree		Star		Mesh		Ring		CSMA/CA	
				CSMA/CD		Hubs, Repeaters, Concentrators		802.1x		Switches & Bridges		Routers & Packet Filtering Firewalls		ICMP (Ping), IPsec, IGMP	
								Common Ports		TCP/UDP, SSL/TLS & BGP		Circuit Proxy Firewall		NetBIOS & RPC	
														Application Firewalls	
														HTTP/S, DNS, SSH, SNMP, LDAP, DHCP	

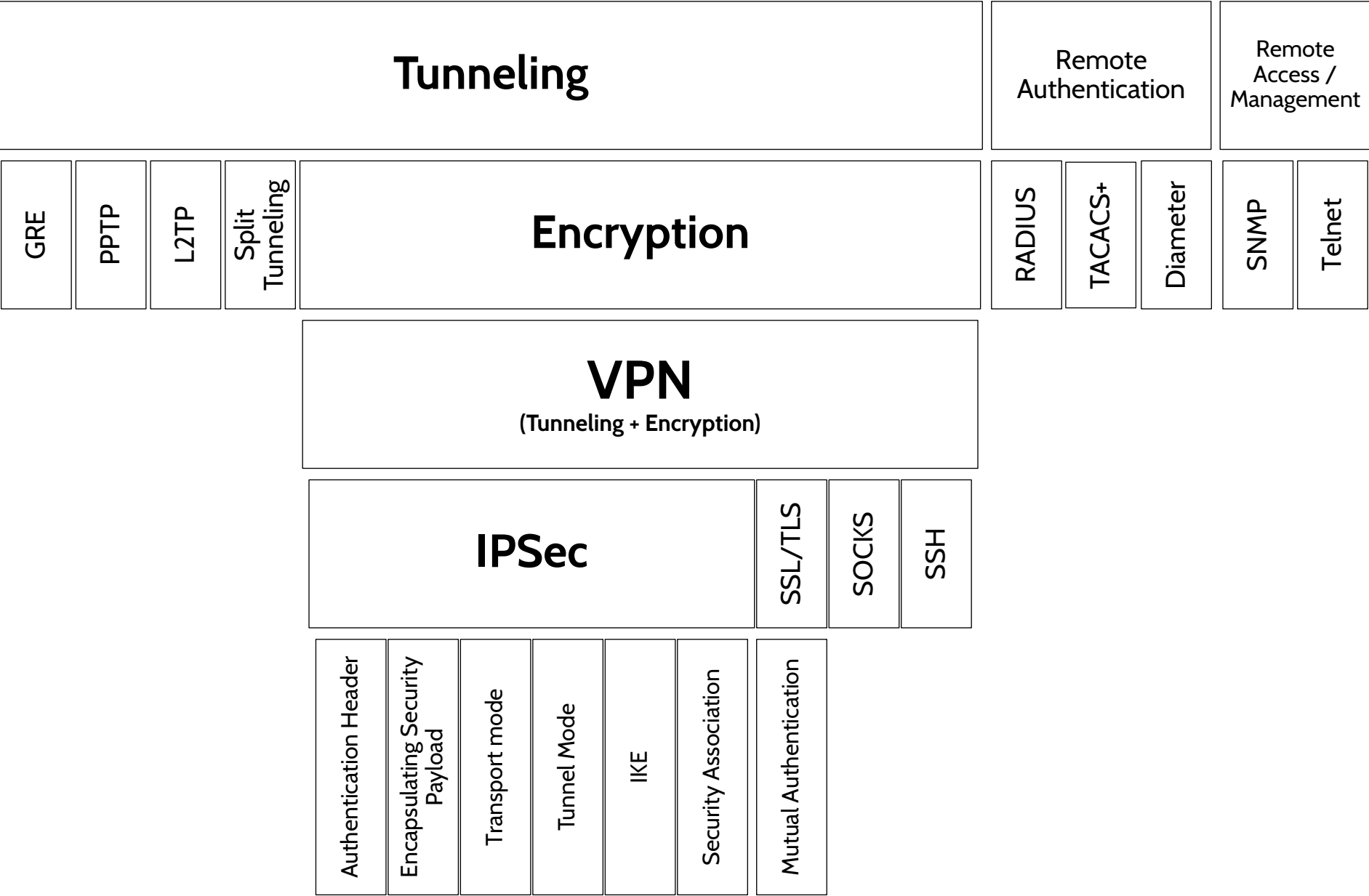
Networking

WAN			Wireless			Internet Protocol (IP) Addresses			Converged Protocols			Network Authentication			Network Attacks			Virtualization			Common Commands																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																								
X.25			Frame Relay			ATM			MPLS			Wi-Fi			WiMAX			GSM / CDMA			Microwave			IPv4 vs. IPv6			IPv4 Network Classes			Private IPv4 Addresses			VoIP			iSCSI, FCoE			PAP			CHAP			EAP			PEAP			Phases			Eavesdropping			SYN Flooding			IP Spoofing			DoS / DDoS			Man-in-the-Middle			ARP poisoning			VLAN			SDN			ipconfig			ping			tracert			whois			dig																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																			
802.11a, b, g, n, ac, ax			Protocols			Encryption			802.16			Reconnaissance			Enumeration			Vulnerability Analysis			Exploitation			Northbound & Southbound APIs																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																					
WEP																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																																													

Network Defense

Defense in Depth	Network Segmentation / Partitioning					Firewalls		Inspection							Endpoint Security	
	Network Perimeter		Types					IDS	IPS	IDS/IPS Location	IDS / IPS Detection Methods			Honeypots & honeynets		Ingress vs. Egress
	DMZ															
	Bastion Host															
	Proxy															
	NAT / PAT															
	Packet Filtering	Stateful Packet Filtering	Circuit Proxy	Application	Host Based	Network Based	Pattern	Anomaly	White & Black Lists	Sandbox						
	In-line	Mirror, Span, Promiscuous	Signature analysis	Stateful matching	Statistical	Protocol	Traffic									

Remote Access





Domain 5

Identity and Access Management

Access Control

Access Control Principles		Administration Approaches		Access Controls Services														Session Management			
Separation of Duties	Need to Know	Least Privilege	Centralized	Decentralized	Hybrid	Identification	Authentication										Authorization	Accountability	Session Hijacking		
				Knowledge	Ownership	Characteristic										Single / Multifactor Authenticator Assurance Levels (AAL)	Just-in-time Access	Discretionary	Non-discretionary	Mandatory	Principle of Access Control
	Hard Tokens	Soft Tokens	Synchronous	Asynchronous	Password	Passphrase	Questions	One-time Passwords	Smart / Memory Cards	Physiological	Behavioural	Templates	Type 1: False Reject	Type 2: False Accept	Crossover Error Rate		Rule	Role	Attribute / Content		
	Fingerprint	Hand Geometry	Vascular Pattern	Facial	Iris	Retina	Voice	Signature	Key Stroke	Gait											

Single Sign-on / Federated Access

Allows users to access multiple systems with a single set of credentials

Single Sign-on

Access systems **within the same organization**

Federated Identity Management (FIM)

Access systems across **multiple entities**

Kerberos

Sesame

Trust
Relationship

SAML

WS-Federation

OpenID

OAuth

Components

Symmetric
encryption only

Symmetric &
Asymmetric
encryption

Principal / User

Identity Provider

Relying Party /
Service Provider

Tokens

Assertions
written in XML

Components

User / Client

Key Distribution
Center

Authentication
Service

Ticket Granting
Ticket (TGT)

Ticket Granting
Service

Service Tickets

Service

Profiles

Bindings

Protocol

Assertion



Domain 6

Security Assessment and Testing

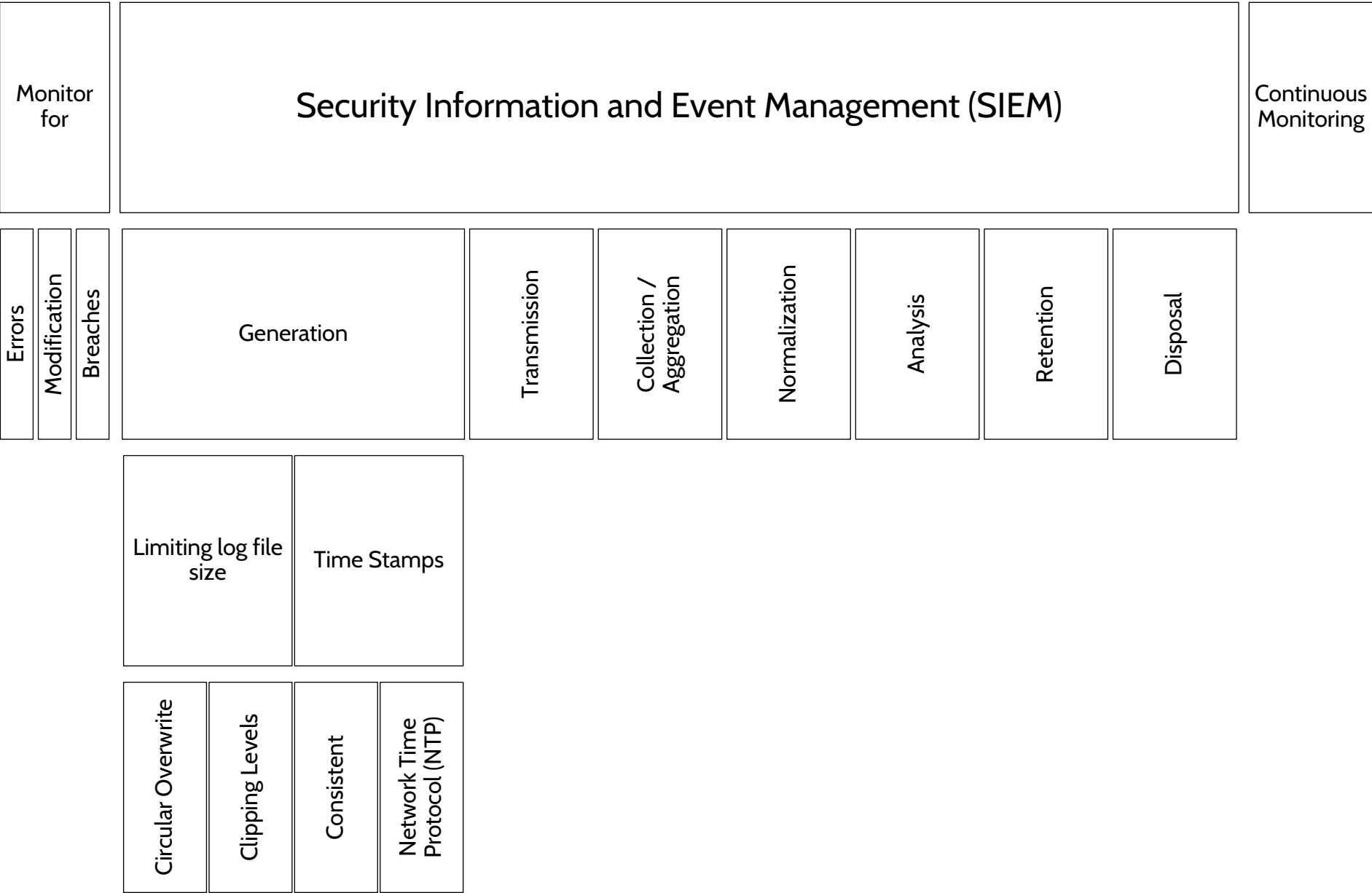
Security Assessment and Testing

Validation	Verification	Rigour	Testing a System	Testing Techniques	Testers / Assessors	Metrics
Unit	Interface	Integration	System	Methods & Tools	Internal	External
Runtime	Access to Code	Techniques	Efficiency	Operational	Third-Party	Roles
Manual	Automated	Static	Dynamic	Fuzz	White	Black
Positive	Negative	Misuse	Decision table analysis	State-based analysis	Boundary Value Analysis	Equivalence Partitioning
Real User Monitoring	Synthetic Performance Monitoring	Regression Testing	SOC 1	SOC 2	SOC 3	Executive Management
Audit Committee	Security Officer	Compliance Manager	Internal Auditors	External Auditors	Type 1	Type 2
Focus	KPIs	KRIs				

Identifying Vulnerabilities

Vulnerability Assessment	Penetration Testing	Process			Testing Techniques			Types of Scans	Banner grabbing & Fingerprinting	Interpreting & understanding results	SCAP	False positive vs. False negative
Reconnaissance	Enumeration	Vulnerability Analysis	Execution	Document Findings	Perspective	Approach	Knowledge	Credentialed / Authenticated	Uncredentialed / Unauthenticated	CVE	CVSS	
Internal	External	Blind	Double-blind	Zero (black)	Partial (gray)	Full (white)						

Log Review & Analysis





Domain 7

Security Operations

Investigations

Secure the Scene	Collect & Control Evidence										Types of Evidence				Rules of Evidence				Investigative Techniques			Types of Investigations			Document & Report																						
	Locard's Principle		MOM		Sources						Chain of Custody				Real Evidence		Direct Evidence		Secondary Evidence		Best Evidence Rule		Authentic			Accurate		Complete		Convincing /		Admissible		Media Analysis		Software Analysis		Network Analysis		Criminal		Civil		Regulatory		Administrative	
											Chain of Custody																																				
	Oral / Written statements		Documents		Digital Forensics						Chain of Custody				Real Evidence		Direct Evidence		Secondary Evidence		Best Evidence Rule		Authentic			Accurate		Complete		Convincing /		Admissible		Media Analysis		Software Analysis		Network Analysis		Criminal		Civil		Regulatory		Administrative	
	Live Evidence (Volatile)		Secondary Storage (HD)		Digital Forensics						Chain of Custody				Real Evidence		Direct Evidence		Secondary Evidence		Best Evidence Rule		Authentic			Accurate		Complete		Convincing /		Admissible		Media Analysis		Software Analysis		Network Analysis		Criminal		Civil		Regulatory		Administrative	
	VM Instance / Virtual Disk																																														
				Digital Forensics						Chain of Custody				Real Evidence		Direct Evidence		Secondary Evidence		Best Evidence Rule		Authentic		Accurate		Complete		Convincing /		Admissible		Media Analysis		Software Analysis		Network Analysis		Criminal		Civil		Regulatory		Administrative			

Incident Response

Prep.

Triage

**Action /
Investigation**

Recovery

Detection

Response
IR Team
Deployed

Mitigation
Containment

Reporting
Relevant
Stakeholders

Recovery
Return to
normal

Remediation
Prevention

**Lessons
Learned**
Improve
Process

Sources:

SIEM, IDS/IPS
DLP, Fire
detectors
Etc.

Event

Incident

Malware

Types of Malware

Virus

Worm

Companion

Macro

Multipartite

Polymorphic

Trojan

Botnets

Boot Sector

Hoaxes / Pranks

Logic Bombs

Stealth

Ransomware

Rootkit

Spyware / Adware

Data Diddler / Salami
Attack

Zero Day

Anti-Malware

Policy

Prevention

Detection

Continuous Updates

Training & Awareness

Allow List

Network Segmentation

Signature Based Scanners

Heuristic Scanners

Activity Monitors

Change Detection

Patching

Determine if Patch is available

Threat
Intelligence

Vendor
Notification

Pro-actively checking

Agent

Agentless

Passive

Implement through Change Management

Timing

Deploy

Automated

Manual

Change Management

Change
Request

Assess
Impact

Approval

Build & Test

Notification

Implement

Validation

Version &
Baseline

Emergency
Change vs.
Standard
process

Based on
impact,
severity, etc.

CCB
CAB
ECAB

Test New
Functionality

Regression
Testing

Recovery Strategies

Backup Storage

Spare Parts

RAID
Redundant Array
of Independent
Disks

High
Availability
System

Recovery Sites

Archive Bit

Types of
Backups

Validation

Data
Storage

RPO

Cold

Warm

Hot

RAID 0
Striping

RAID 1
Mirroring

RAID 5
Parity

RAID 6
Double Parity

Clustering

Redundancy

Types of Sites

Geographically remote

Mirror

Full

Incremental

Differential

Checksums / CRC

Offsite

Tape Rotation

Cold

Warm

Hot

Mobile

Mirror / Redundant

Business Continuity Management (BCM)

Focuses on critical and essential functions of business

Goals of BCM

1. Safety of people
2. Minimize damage
3. Survival of business

Business Impact Assessment

Identify Critical Processes & Systems

Measurements of Time

Owner approval of #s and associated costs

Types of Plans

Business Continuity Plan (BCP)

Disaster Recovery Plan (DRP)

Read-through / Checklist

Walkthrough

Simulation

Parallel

Full-interruption / Full-scale

Restoration order

Most critical first

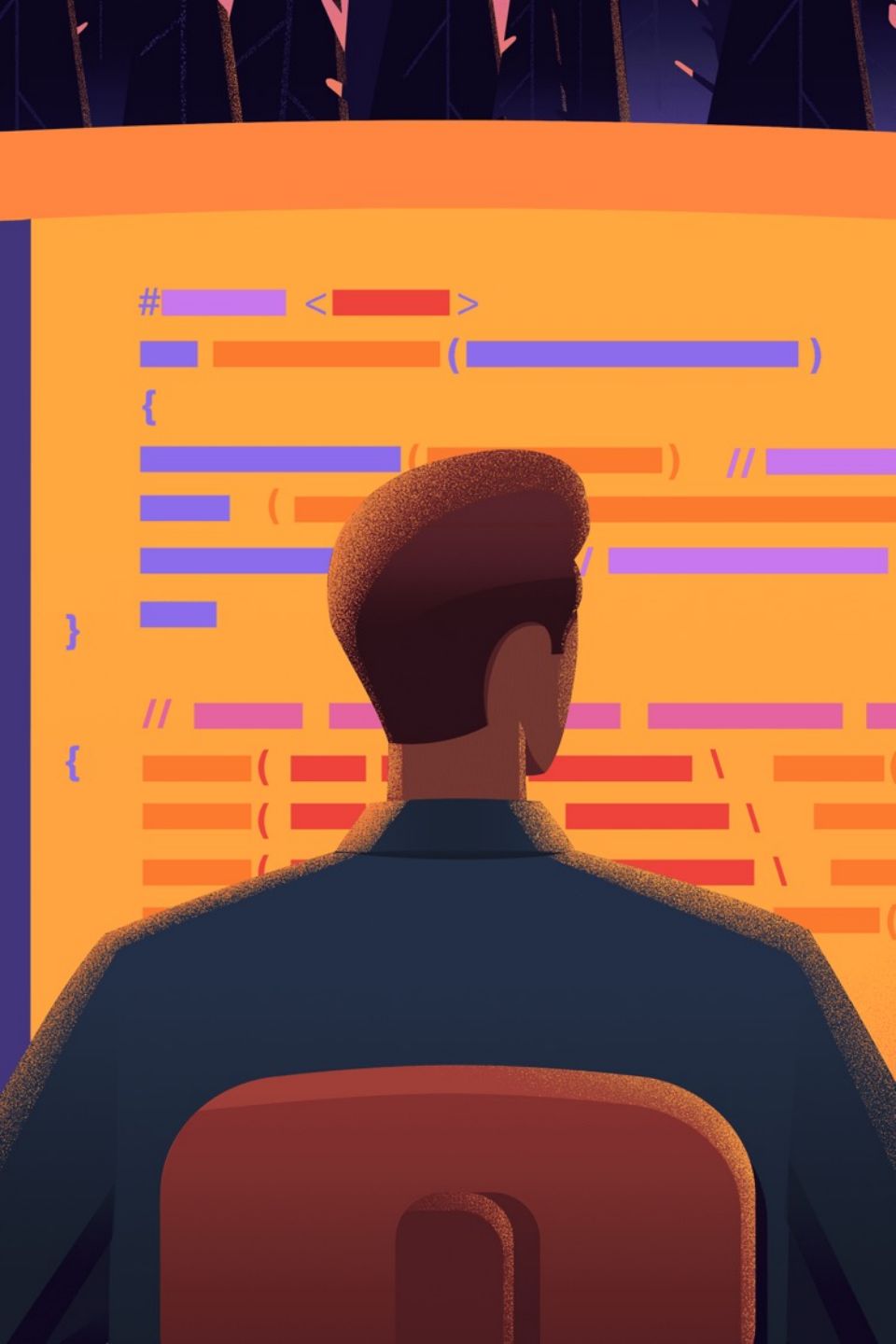
Dependency charts

RPO

RTO

WRT

MTD



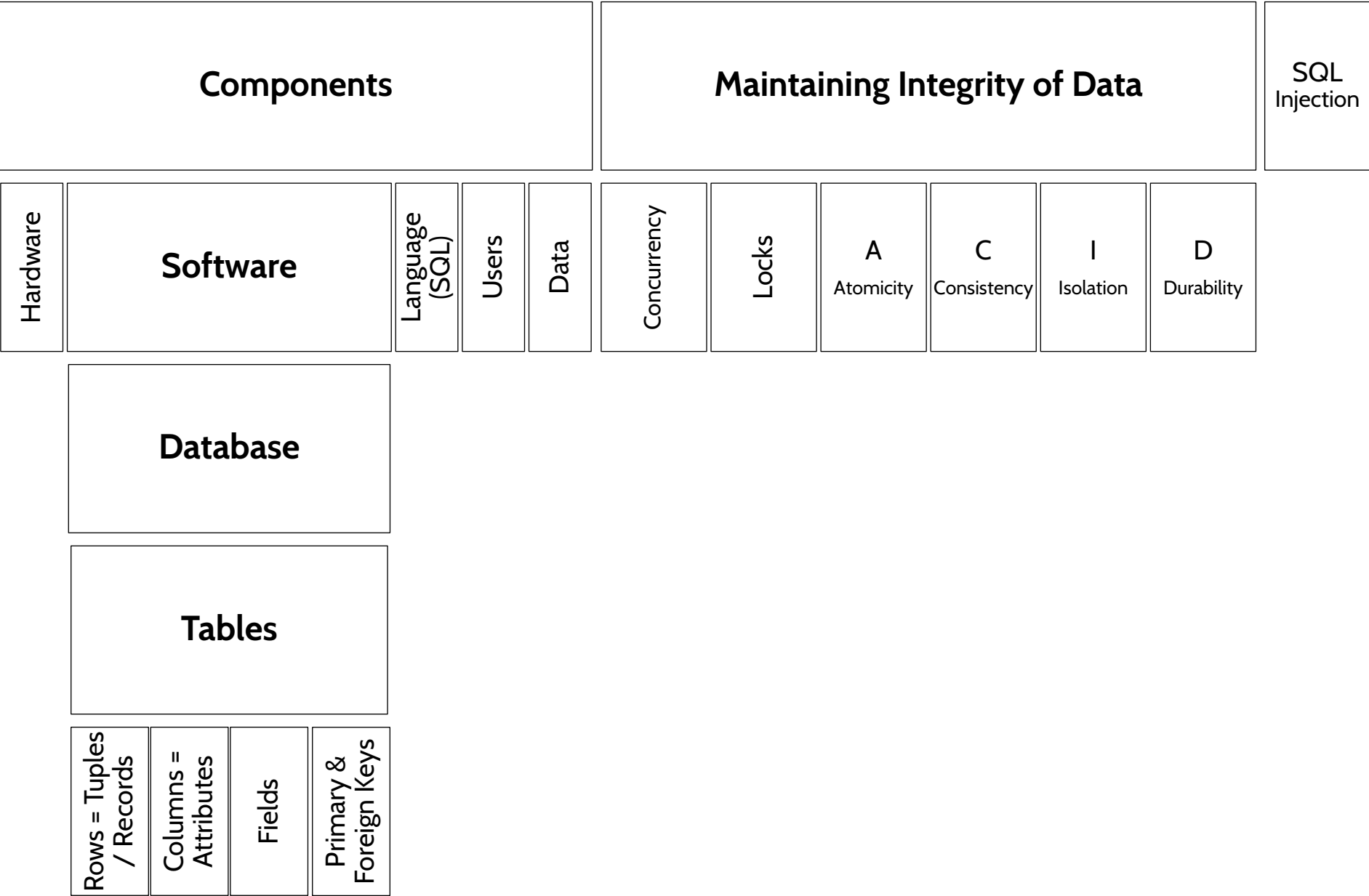
Domain 8

Software Development Security

Secure Software Development

Bake In Security	System Life Cycle (SLC)										Maturity Models										APIs										Obfuscation										Acquire Software										Software Security Weaknesses & Vulnerabilities										Secure Programming										Maintain Software																																																																																																																																											
	Software Development Life Cycle (SDLC)										Operation										Disposal										REST										SOAP										Lexical, Data, Control flow										Assess vendors										Contracts, / SLAs										Buffer Overflows										SQL Injection										XSS / CSRF										Covert Channels										Backdoors / Trapdoors										Memory / Object Reuse										TOCTOU										Citizen Developers										Input Validation										Session Management										Polynomialization										SCM										SOAR									
	Plan + Mgmt. Approval										Requirements										Architecture & Design										Development										Testing										Deployment																																																																																																																																																															
	Cannot go back										Sprints										Scrum Master																																								Combine Dev, QA & Ops										SecDevOps																																																																																																																																											
	Waterfall										Agile										DevOps										Canary										Certification										Accreditation																																																																																																																																																															

Databases



Printable Blank MindMaps

Print out the following blank MindMaps and fill them in as you watch our MindMap videos!

Print pages **41** to **70**

Alignment of Security Function to Business Strategy

[illegible]

Privacy

--

--	--	--	--	--	--

--	--	--	--	--	--	--	--	--	--	--	--	--	--	--	--	--	--	--	--	--

Intellectual Property

--	--	--	--

Risk Management

Asset Classification

[illegible]

Models

Secure Design Principles

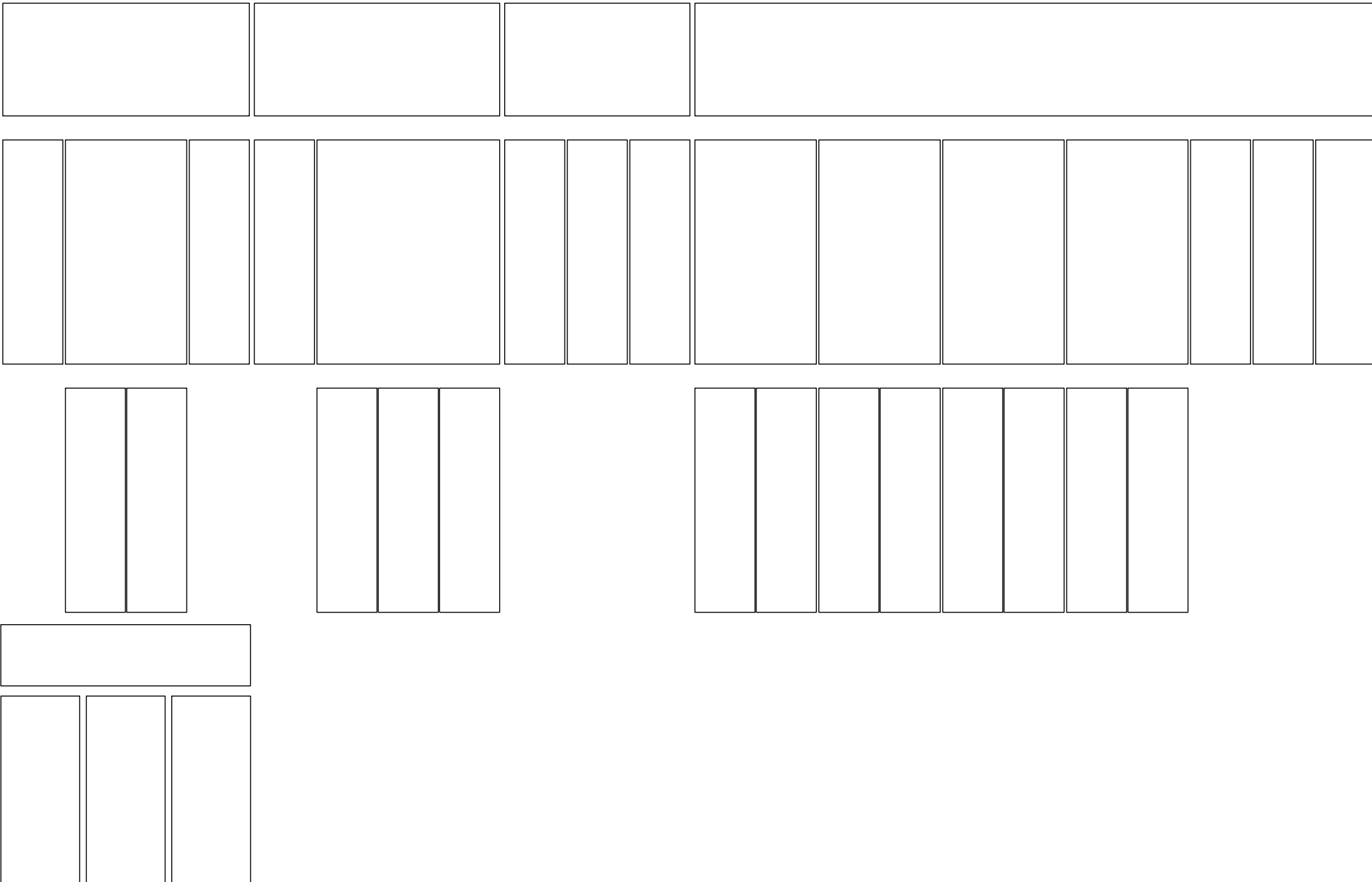
[illegible]

Security Frameworks

[illegible]

Evaluation Criteria

Trusted Computing Base (TCB)



Vulnerabilities in Systems

The diagram illustrates a hierarchical tree structure. At the top is a single root node. This root node branches into two main nodes. The left main node further branches into four leaf nodes, while the right main node branches into three leaf nodes. This structure represents a binary tree where each internal node has two children, and the leaf nodes represent the final data points or results of the hierarchy.

Web-based Vulnerabilities

Cloud Computing

[illegible][illegible]

--	--

--	--	--	--	--

Cryptographic Services

Cryptographic terminology

Secret Writing

Digital Signatures

Digital Certificates

PKI

Key Management

Cryptanalysis

--

--	--	--	--	--	--	--

--

--	--	--	--	--	--	--	--	--	--

--	--	--

--	--

Physical Security

--

--	--

--	--	--	--	--	--	--	--	--	--	--	--	--	--	--	--	--	--

--	--

--	--	--	--

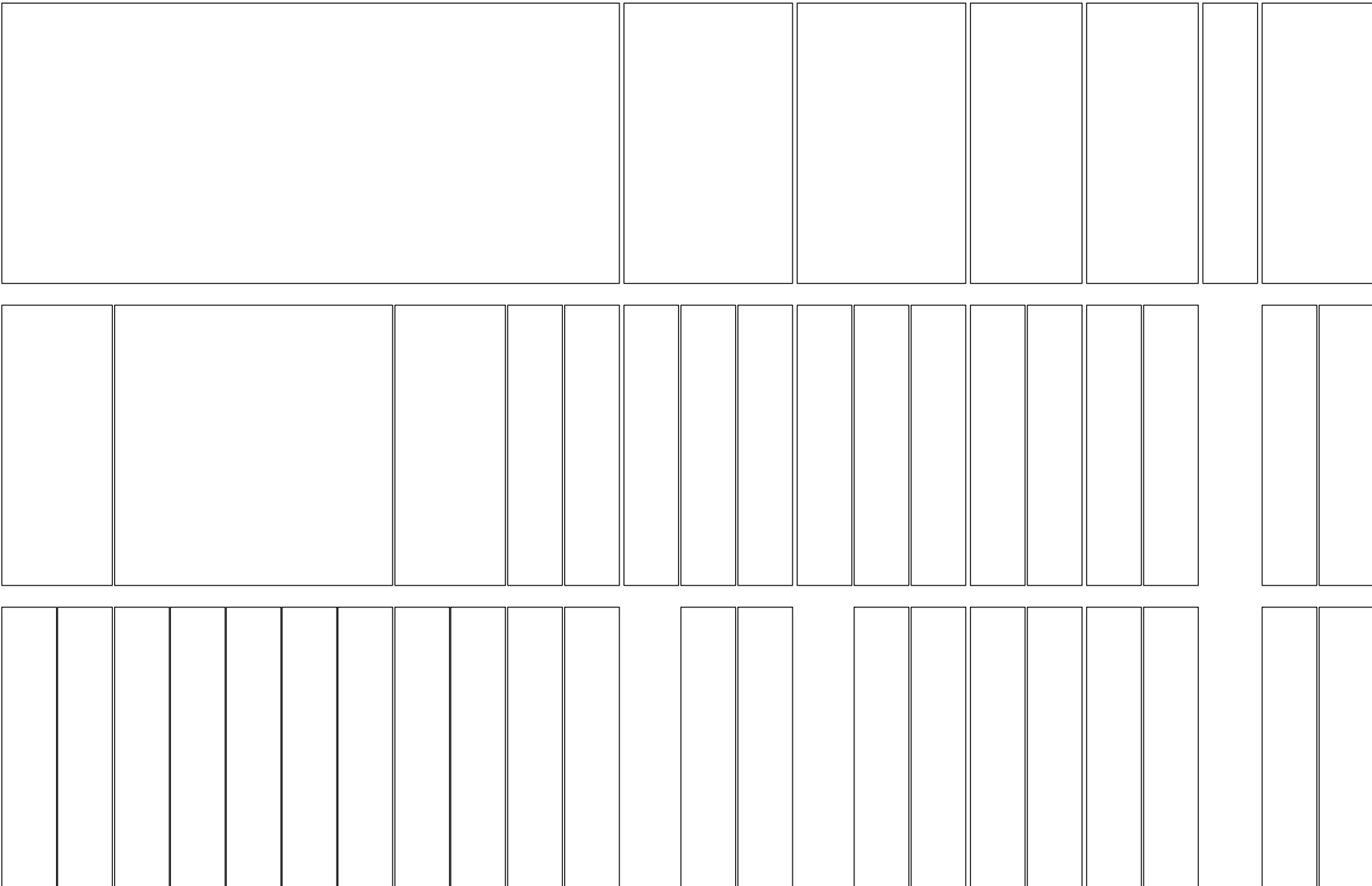
--	--	--	--	--	--	--	--	--	--	--	--	--	--	--

--	--	--	--	--	--	--

--	--	--

--	--

Open Systems Interconnection (OSI) Model



Networking

--	--	--	--	--	--	--	--

[illegible]

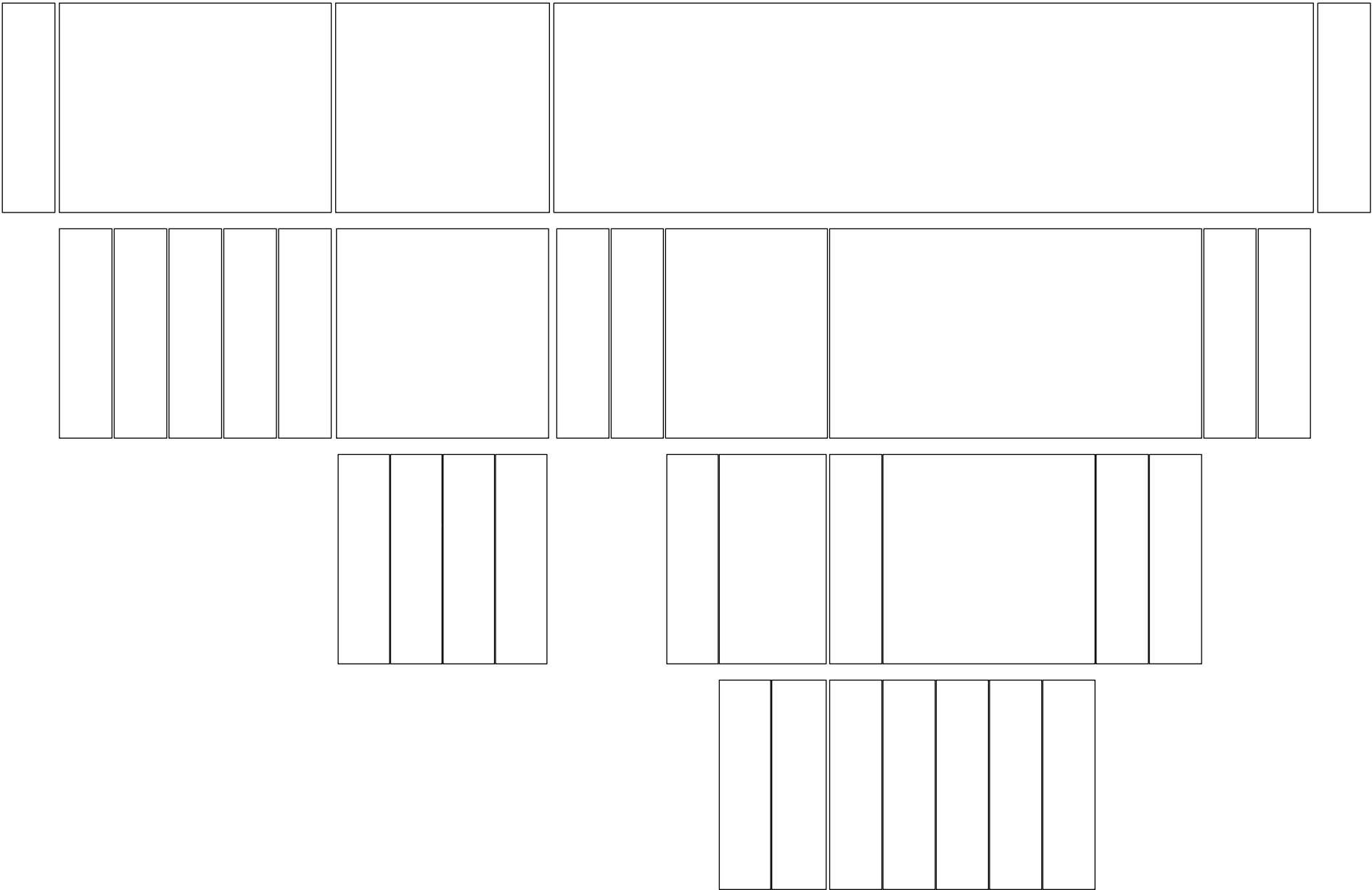
--	--	--

--	--	--	--

--	--	--	--

--	--

Network Defense



Remote Access

Access Control

[illegible]

Single Sign-on / Federated Access

Security Assessment and Testing

[illegible]

Identifying Vulnerabilities

[illegible]

Log Review & Analysis

Investigations

[illegible]

Incident Response

[illegible]

Malware

--

--

--

--	--	--	--	--	--	--	--	--	--	--	--	--	--	--	--

--	--	--	--

--	--	--	--	--	--	--

Patching

Change Management

Recovery Strategies

Business Continuity Management (BCM)

--

--	--	--	--	--

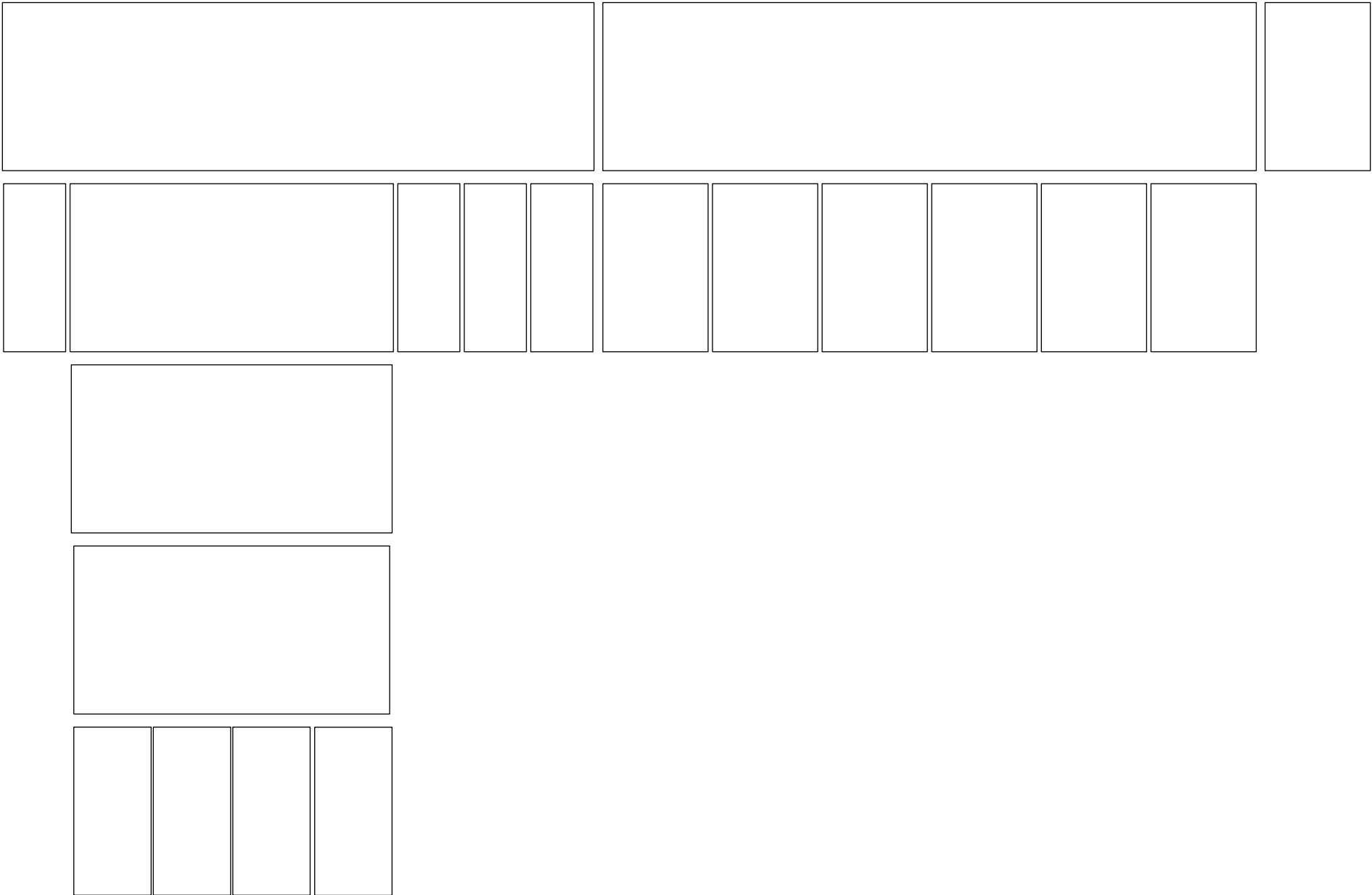
--	--	--	--	--	--	--	--	--	--	--	--	--	--	--

--	--	--	--

Secure Software Development

[illegible]

Databases



Hi there!

I hope our CISSP MindMaps have helped identify the critical concepts you need to know for the exam!

These MindMaps are a small part of our complete CISSP MasterClass.

If you're looking for detailed explanations of all the concepts covered in these MindMaps + everything else you need to confidently pass the CISSP exam, check out our **CISSP MasterClass** here: destcert.com/CISSP

We have guided thousands of folks to confidently pass the CISSP exam over the last 20+ years. We provide expert instruction and an integrated intelligent system of study resources and tools.

All the best in your studies!



Rob Witcher

Co-founder & Master Instructor